Informe de incidente de seguridad.

1. Introducción.

Se ha ejecutado un análisis forense en un servidor de Debian que estaba comprometido, mientras se realizaba este análisis se logro identificar un acceso no autorizado mediante SSH, ademas de múltiples vulnerabilidades de configuración que concedía una exposición del sistema.
Se emplearon medidas correctivas con el fin de:

- Contener el ataque.
- Eliminar los riesgos.
- Fortalecer la seguridad del servidor.

2. Datos del entorno.

Sistema operativo:	Debian Linux
Servicios activos:	SSH, FTP, Apache
Aplicaciones:	WordPress
Entorno:	Máquina virtual
IP del servidor:	192.168.1.148
IP sospechosa:	192.168.0.134

3. Gestión del incidente.

Se ejecutaron las siguientes acciones:

1. Análisis de logs del sistema
2. Verificación de sesiones activas.
3. Revisión de usuarios y accesos.
4. Escaneo de servicios activos.
5. Identificación de vulnerabilidades.

Y posteriormente:

1. Se bloquearon vectores de acceso.
2. Se corrigieron configuraciones insegura.
3. Se aplicaron medidas de hardening.

4. Analisis forense.

4.1 Análisis de logs.

-Acceso no autorizado detectado

Tras un análisis se detecto el indicio sospechoso de un log “Accepted password for root from 192.168.0.134” lo cual indica que alguien accedió como root por SSH usando contraseña. Ademas, no existían restricciones de acceso remoto.

4.2 Análisis de usuario.

Tras un extenso análisis no se detectaron usuarios adicionales sospechosos ni cuentas creadas por el atacante.

Usuarios con shell	***Usuarios con UID 0***
root	root
debian	
No se detectaron usuarios maliciosos pero el atacante no necesitaba crear usuarios pues ya tenia root.	

4.3 Análisis de red.

Se identifico una salida relevante (ss -tulpn) junto con varios puertos abiertos.

21	*FTP abierto*
22	*SSH abierto*
80	*HTTP abierto*

Múltiples servicios expuestos innecesariamente dando lugar a una superficie de ataque amplia.

4.4 Análisis del sistema de archivos.

Se reviso el directorio /tmp el cual contiene archivos temporales pero no se encontraron artefactos evidentes.

4.5 Análisis de autenticación.

Se identifico una configuración altamente insegura el cual fue el vector principal del ataque.

- Acceso root permitido
- Autenticación por contraseña activo.

4.6 Análisis web – WordPress.

Se encontró tras el análisis las siguientes cualidades:

- /wp-admin accesible
- robots.txt revela rutas
- xmlrpc.php activo
- directory listing habilitado
- usuario identificado: wordpress-user

Esto deja vulnerable el sistema a ataques de fuerza bruta, enumeración de puertos y explotación web.

4.7 Análisis de FTP.

Fue identificado un mensaje “Anonymous FTP login allowed” dando intrepretacion al logro de un acceso sin autenticación el cual podría dar lugar a un posible vector de carga de archivos.

5. Intento de explotación.

Se identificaron los siguientes factores:

- Enumeración con dirb.
- Escaneo con wpscan.
- Descubrimiento de usuario.
- Intento de fuerza bruta.

Demostrando la explotabilidad real del servidor debian.

6. Impacto del incidente.

El impacto de esta situación radica en la confirmación del acceso root dando lugar al control total del sistema. El impacto potencial de este evento puede dar ocasión a:

- Exfiltración de datos.
- Modificación del sistema.
- Instalación de malware.
- Pivoting a otros sistemas.

7. Atribución.

Se identifico la IP del atacante como “192.168.0.134”. Esto nos da a entender que no fue un ataque sofisticado, de origen interno y que uso credenciales validas.

```
Oct 08 17:40:59 debian sshd[1650]: Accepted password for root from 192.168.0.134 port 45623 ssh2
Oct 08 17:40:59 debian sshd[1650]: pam_unix(sshd:session): session opened for user root(uid=0) by (uid=0)
Oct 08 17:40:59 debian sshd[1650]: pam_env(sshd:session): deprecated reading of user environment enabled
-- Boot d3ce1081830e48f0aa84ae91af996d83 --
```

8. Acciones correctivas.

SSH – Se deshabilito el acceso root:

```
grep: /etc/ssh/sshd_config: No such file or directory
debian@debian:~$ sudo grep PermitRootLogin /etc/ssh/sshd_config
PermitRootLogin no
# the setting of "PermitRootLogin prohibit-password".
```

Se deshabilito la autenticación por contraseña:

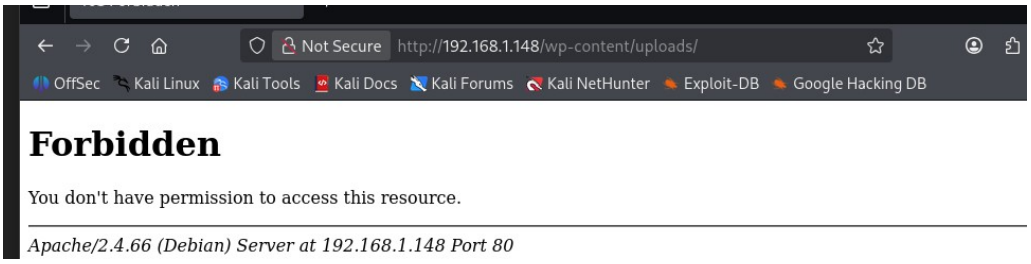
```
debian@debian:~$ sudo grep PasswordAuthentication /etc/ssh/sshd_config
PasswordAuthentication no
```

FTP – Se deshabilito el acceso anónimo:

```
debian@debian:~$ sudo grep anonymous_enable /etc/vsftpd.conf
anonymous_enable=NO
```

Apache/WordPress - Se desactivo el directory listing, el bloqueo de xmlrpc.php y la eliminación de archivos informáticos:

```
<Directory /var/www/>
        Options -Indexes +FollowSymLinks
        AllowOverride None
        Require all granted
```




```
debian@debian:~$ sudo cat /etc/apache2/conf-enabled/block-xmlrpc.conf
<Files "xmlrpc.php">
    Require all denied
</Files>
```

Firewall – Se cerro el acceso a puertos abiertos innecesariamente.

```
debian@debian:~$ sudo ufw status
Status: active

To                         Action      From
--                         ------      ----
22                         ALLOW       Anywhere
80                         ALLOW       Anywhere
22 (v6)                    ALLOW       Anywhere (v6)
80 (v6)                    ALLOW       Anywhere (v6)
```

9. Medidas preventivas.

Para evitar que se repitan incidentes como el presente se implementaran las siguientes acciones.

Control de acceso.	• Usar exclusivamente la autenticación por clave SSH. • Implementar MFA. • Aplicar principio de mínimo privilegio.
Hardening.	• Deshabilitar los servicios innecesarios. • Hacer una revisión periódica de las configuraciones. • Control de permisos.
Monitoreo.	• Realizar un análisis continuo de los logs. • Aplicar alertas de accesos sospechosos.
Seguridad de red.	• Segmentación de red.